

API Reference (v1)

Base path: `/api/v1`. All endpoints require an authenticated session unless marked **public**.

Authentication

Session-cookie based. `POST /api/v1/auth/login` sets an `httpOnly dk_session` cookie and a readable `dk_csrf` cookie. Mutating requests using the cookie must echo the CSRF token in the `x-csrf-token` header. API clients may instead send `Authorization: Bearer <token>` (CSRF is not enforced for bearer auth).

Response envelope

Success:

```
{ "success": true, "data": { }, "meta": { "timestamp": "...", "requestId": "..." } }
```

Error:

```
{ "success": false, "error": { "code": "VALIDATION_ERROR", "message": "...", "requestId": "..." } }
```

Permissions

Permissions use the form `module:resource:action` (e.g. `identity:users:read`).

Wildcards are supported in role grants: `*`, `catalogue:*:read`, `branding:*:*`.

Role	Grants
super_admin	<code>*</code>
tenant_admin	<code>*</code> (within tenant)
manager	catalogue r/w, branding all, theme content r/w
staff	catalogue read, theme content read
customer	catalogue read

Endpoints

See `README.md` for the full endpoint list. Notable behaviours:

- **Configuration** is hierarchical: platform defaults (`tenantId = null`) are overridden by tenant-specific values. Secret values are encrypted at rest and masked in responses.

- **Feature flags** resolve per tenant. `PERCENTAGE` flags bucket consistently by a hash of the subject id. Tenant overrides take precedence over the default value.
- **Services:** credentials are encrypted (AES-256-GCM) before storage and always returned masked. `POST /:type/test` performs a live connection test and records health. Adapters gracefully fall back when unconfigured.
- **Events:** `publishEvent` writes to the transactional outbox and attempts inline relay; the `POST /events/relay` CRON endpoint retries pending/failed events. Inbound `POST /events/:handler` verifies the signature and is idempotent.